

ЛАБОРАТОРНА РОБОТА № 1

Хід роботи:

Завдання 1: Дослідження методів соціальної інженерії.

Крок 1: Ознайомлення з методами Приманювання (Baiting), Підглядкування з-за плеча (Shoulder Surfing) та Вигаданий привід (Pretexting). Національний центр підтримки безпеки систем та забезпечення інформації (CSSIA, National Support Center for Systems Security and Information Assurance) проводить захід Інтерактивна соціальна інженерія., а потім скористайтесь вмістом для відповідей на такі запитання.

Що таке Приманювання (Baiting)? Ви натиснули на USB-накопичувач? Що сталося з системою жертви?

- Приманювання (Baiting) - це метод, коли зловмисник залишає заражені USB-накопичувачі в громадських місцях, спонукаючи жертву через цікавість вставити їх у комп'ютер, що призводить до запуску шкідливого ПЗ. Ні, не натиснули на USB-накопичувач - це уникає зараження системи жертви малвар'ю, крадіжки даних чи блокування доступу.

Що таке Підглядкування з-за плеча (Shoulder Surfing)? Який пристрій було використано для виконання підглядкування з-за плеча? Яку інформацію було отримано?

- Підглядкування з-за плеча (Shoulder Surfing) - це спостереження за екраном чи введенням даних жертви в людних місцях. Використано камеру смартфона; отримано PIN-код банкомата чи пароль.

Що таке Вигаданий привід (Pretexting)? Інформацію якого типу запитав кіберзлочинець? Ви б стали жертвою?

- Вигадний привід (Pretexting) - створення фальшивої ролі (наприклад, IT-підтримка) для витягування конфіденційної інформації. Кіберзлочинець запитав логін/пароль чи фінансові дані; ні, я б не став жертвою, бо завжди перевіряю джерело запиту.

					ДУ «Житомирська політехніка».26.121.20.000 – Лр1						
Змн.	Арк.	№ докум.	Підпис	Дата							
Розроб.		Риженко Я.В.			Звіт з лабораторної роботи			Літ.	Арк.	Аркушів	
Перевір.		Лобанчикова Н.М.							1	12	
Керівник								ФІКТ Гр. ІПЗ-23-1			
Н. контр.											
Зав. каф.											

Крок 2: Дослідження методів Фішинг (Phishing), Спрямований фішинг (Spear Phishing) та Уелінг (Whaling)

Фішинг призначений для того, щоб змусити жертв виконувати такі дії: натискати посилання на шкідливі веб-сайти; відкривати вкладення, які містять шкідливе програмне забезпечення; розкривати конфіденційну інформацію. Використайте інтерактивне завдання, щоб вивчити різні методи фішингу.

Який трюк у наведеному прикладі фішингу використовує зловмисник для обману жертви, що спонукає до відвідування веб-сайту-пастки? Для чого використовується веб-сайт-пастка?

- Трюк - підроблений URL у email (наприклад, g00gle.com замість google.com), що спонукає клацнути та відвідати пастку. Веб-сайт-пастка імітує легітимний сайт для крадіжки логінів, паролів чи встановлення малварі.

У чому відмінність між такими методами як Фішинг (Phishing), Спрямований фішинг (Spear Phishing) та Уелінг (Whaling)?

- Відмінність Phishing, Spear Phishing, Whaling: Phishing - масові email-атаки; Spear Phishing - персоналізовані на конкретну особу; Whaling - на високопосадовців (CEO).

Крок 3: Ознайомлення з програмами-залякувачами (Scareware) та програмами-вимагачами (Ransomware)

Програма-залякувач (Scareware) – це програма, яка надсилає користувачеві-жертві фальшиві сигнали тривоги та формує у нього думку, що його система інфікована зловмисним програмним забезпеченням, та спонукає користувача до встановлення непотрібного або зловмисного програмного забезпечення. Програма-вимагач (Ransomware) – це тип зловмисного програмного забезпечення, яке загрожує опублікувати або шифрує дані жертви, перешкоджаючи доступу до цих даних чи можливості їх використання. Жертві блокується доступ до її системи або до особистих файлів, допоки вона для відновлення доступу не внесе викуп.

Які дані, як стверджує, має зловмисник у цьому прикладі? Чи піддалися б ви такому обману?

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Пр1	Арк.
		Лобанчикова Н.М.				2
Змн.	Арк.	№ докум.	Підпис	Дата		

- Зловмисник стверджує, що має/заблокувало особисті файли жертви (фото, документи); ні, я б не піддався обману, бо маю резервні копії та не платитиму викуп. Зловмисники зазвичай вимагають криптовалюту (Bitcoin) за ключ розшифрування даних.

Що зловмисник вимагає від жертви для повернення даних?

- Зловмисник вимагає грошовий викуп (ransom), який часто потрібно сплатити у криптовалюті (наприклад, Bitcoin, Monero), щоб зберегти анонімність. В обмін на оплату він обіцяє надати програмний ключ або інструмент для розшифрування даних.

Що таке несанкціоноване проникнення «на хвості» (Tailgating)?

- Tailgating (або «проникнення на хвості») - це метод соціальної інженерії, коли неавторизована особа проникає за авторизованим співробітником у закриту зону (офіс, серверну, лабораторію), фізично прямуючи слідом. Зловмисник може вдавати, що несе важкі коробки або забув перепустку, розраховуючи на ввічливість людини, яка притримає двері.

Назвіть три способи запобігання атакам соціальної інженерії?

1. Регулярне навчання та підвищення обізнаності персоналу: Проведення тренінгів щодо розпізнавання фішингових листів, підозрілих дзвінків (вішинг) та методів фізичного проникнення (той самий Tailgating).
2. Використання багатофакторної автентифікації (MFA/2FA): Навіть якщо зловмисник викраде пароль за допомогою соціальної інженерії, він не зможе увійти в систему без другого фактора (коду з телефону або біометрії).
3. Суворі політики безпеки та процедури: Впровадження чітких правил (наприклад, не повідомляти паролі телефоном, перевіряти особу відвідувача, обов'язково використовувати перепустки), які мають виконувати всі співробітники без винятку.

Завдання 2: Створення інформаційного плаката про кібербезпеку

Презентація була надіслана разом з лабораторною роботою на пошту викладача.

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Лр1	Арк.
		Лобанчикова Н.М.				
Змн.	Арк.	№ докум.	Підпис	Дата		3

Завдання 3: Додаткові завдання:

Навести скріншот для підтвердження проходження Розділу 1 (1.0-1.6) курсу «Основи кібербезпеки» Академії Cisco:

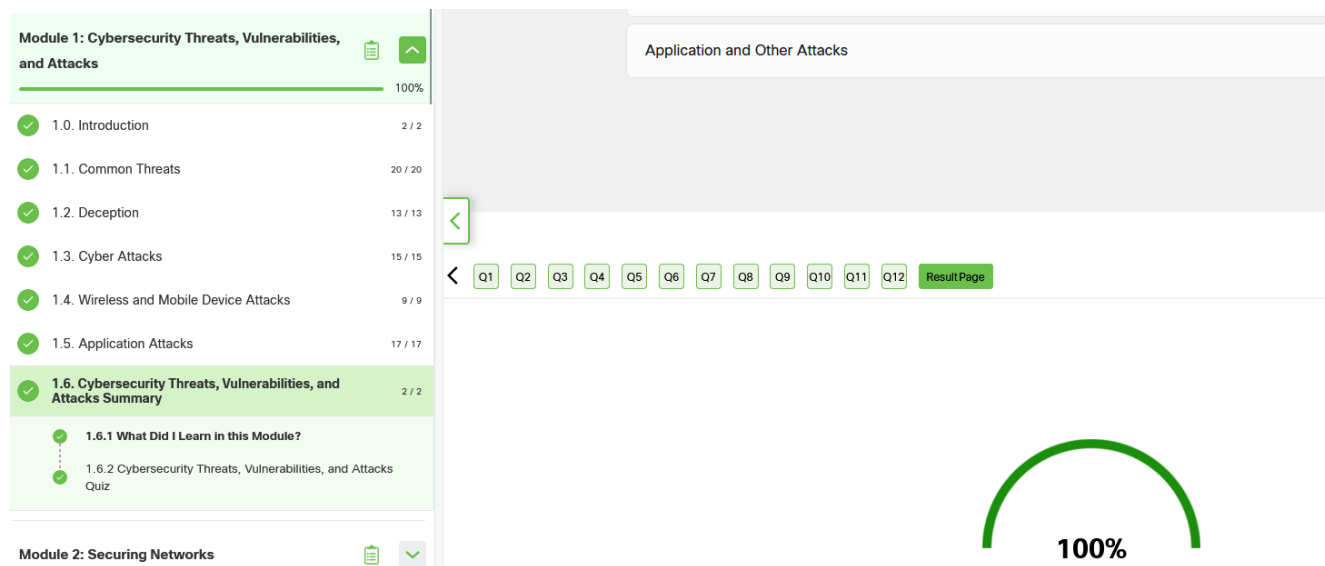


Рис. 1. Скріншот проходження розділу 1.

Висновок: У ході роботи було детально досліджено основні методи соціальної інженерії, які використовуються зловмисниками для отримання несанкціонованого доступу до інформації та фізичних об'єктів організації. Особливу увагу приділено аналізу фізичних загроз, зокрема несанкціонованому проникненню «на хвості», яке часто залишається поза увагою при розробці стратегій безпеки. Розглянуті приклади демонструють, що ефективний захист потребує комплексного підходу, який поєднує технічні засоби, фізичний контроль доступу та постійне підвищення обізнаності персоналу. Створення інформаційних матеріалів та проходження спеціалізованого навчання підтверджують важливість безперервної освіти у сфері кібербезпеки для запобігання як цифровим, так і фізичним атакам.

		Рижченко Я.В.			ДУ «Житомирська політехніка».26.121.20.000 – Пр1	Арк.
		Лобанчикова Н.М.				4
Змн.	Арк.	№ докум.	Підпис	Дата		